



أمن المعلومات تقرير تقييم المخاطر

تصنيف الوثائق	سري
مرجع المستند	ISMS-DOC-06-3
النسخة	1.0
تاريخ	12 September 2026
مؤلف المستند	فريق مشروع ISMS
مالك الوثيقة	مسؤول أمن المعلومات CISO

تاريخ المراجعة

تقرير تقييم مخاطر أمن المعلومات
سري

النسخة	التاريخ	مؤلف المراجعة	ملخص التغييرات
1.0	12 سبتمبر 2026	فريق مشروع ISMS	إعداد تقرير تقييم المخاطر الأول ضمن تنفيذ نظام إدارة أمن المعلومات

التوزيع

الاسم	العنوان
CISO	مسؤول أمن المعلومات
CISO	مسؤول تقنية المعلومات
فريق مشروع ISMS	فريق تنفيذ المشروع

الموافقة

الاسم	المنصب	التوقيع	التاريخ
CISO	مسؤول أمن المعلومات	تم التوقيع إلكترونياً	12 سبتمبر 2026
CIO	مسؤول تقنية المعلومات	تم التوقيع إلكترونياً	12 سبتمبر 2026
CEO	الرئيس التنفيذي	تم التوقيع إلكترونياً	12 سبتمبر 2026

المحتويات

1	مقدمة	4
2	سياق تقييم المخاطر	5
2.1	السياق الداخلي والخارجي	5
2.2	النطاق	6
2.3	معايير قبول المخاطر	6
3	ملخص نتائج تقييم المخاطر	7
3.1	[تقييم المخاطر القائم على الأصول]	
3.2	[تقييم المخاطر بناء على السيناريو]	
4	الملحق أ: تقييم مفصل للمخاطر	

الأرقام

الشكل 1: تقييم المخاطر القائمة على الأصول

الجدول

الجدول 1: فريق تقييم المخاطر	4
الجدول 2: الأشخاص الذين تم استشارتهم	4
الجدول 3: ملخص نتائج تقييم المخاطر (قائم على الأصول)	8
الجدول 4: ملخص نتائج تقييم المخاطر (قائم على السيناريو)	9

يقدم هذا التقرير نتائج تقييم مخاطر أمن المعلومات الذي تم إجراؤه ضمن مشروع تنفيذ نظام إدارة أمن المعلومات ISMS في بنك الأفاق الرقمية.

يهدف التقييم إلى تحديد المخاطر المرتبطة بالأصول المعلوماتية والأنظمة والخدمات الواقعة ضمن نطاق نظام إدارة أمن المعلومات، وتقييم تأثيرها على سرية المعلومات وسلامتها وتوافرها، ثم تحديد المخاطر التي تتطلب المعالجة أو قراراً موثقاً بقبولها من الإدارة.

يعتمد التقييم على المعلومات المتوفرة عن بيئة البنك الرقمية، والأصول المعلوماتية، والخدمات، والحوادث الأمنية السابقة، ونتائج فحص الثغرات، واحتياجات الأطراف المعنية والمتطلبات التنظيمية.

بعد اعتماد نتائج تقييم المخاطر، يتم تحديد إجراءات المعالجة المناسبة وتوثيقها ضمن خطة معالجة المخاطر Risk Treatment Plan ومتابعتها كجزء من نظام إدارة أمن المعلومات.

وتشمل نتائج هذا التقرير:

- تحديد سياق ونطاق تقييم المخاطر.
- تحديد الأصول المعلوماتية الواقعة ضمن النطاق.
- تحديد التهديدات والمخاطر المرتبطة بالأصول.
- تقييم مستوى المخاطر.
- تحديد مالكي المخاطر.
- تحديد ما إذا كان الخطر يحتاج إلى معالجة أو يمكن قبوله.
- تحديد أولويات المعالجة للمخاطر التي تتطلب إجراءً.

ويجب اعتماد نتائج هذا التقييم من الإدارة العليا قبل الانتقال إلى مرحلة معالجة المخاطر.

تم إجراء هذا التقييم للمخاطر من قبل الأشخاص التاليين:

الاسم	الدور في التقييم
فريق مشروع ISMS	فريق تقييم المخاطر
CISO	مسؤول تقييم ومتابعة مخاطر أمن المعلومات
CIO	مسؤول مخاطر تقنية المعلومات

الجدول 1: فريق تقييم المخاطر

كجزء من التقييم، تم استشارة :

الاسم	العنوان
Risk Manager	منسق تقييم المخاطر

الجدول 2: الأشخاص الذين تم استشارتهم

2 سياق تقييم المخاطر

يهدف تقييم المخاطر إلى تحديد المخاطر التي يمكن أن تؤثر على أمن المعلومات ضمن نطاق نظام إدارة أمن المعلومات في بنك الأفاق الرقمية، وتحديد أولويات المعالجة بناءً على مستوى تأثير الخطر واحتمالية حدوثه.

تم إجراء التقييم بالاعتماد على المعلومات المتاحة عن بيئة البنك، بما في ذلك الأصول والخدمات المصرفية الرقمية، والحوادث الأمنية المسجلة، ونتائج فحص الثغرات، والتهديدات التي تواجه البنك، واحتياجات الأطراف المعنية.

ويركز التقييم على حماية:

السرية Confidentiality
السلامة/التكامل Integrity
التوافر Availability

للمعلومات والأنظمة والخدمات الواقعة ضمن نطاق ISMS.

2.1 السياق الداخلي والخارجي

2.2 السياق الداخلي

يشمل السياق الداخلي للبنك:

- الاعتماد على الخدمات المصرفية الرقمية.
- وجود بيانات عملاء وبيانات موظفين حساسة.
- وجود معلومات مالية ومعلومات خاصة بالخرزينة.
- وجود تطبيقات وقواعد بيانات وأنظمة مصرفية.
- وجود بنية تحتية للشبكات والأمن.
- وجود سجلات أمنية وسجلات أنظمة.
- وجود مركز بيانات رئيسي في الرياض.
- وجود موقع للتعافي من الكوارث في جدة.
- وجود أنظمة وأدوات أمنية وتقنية متعددة.
- وجود حوادث أمنية وتشغيلية موثقة.
- وجود نتائج لفحص الثغرات تحتاج إلى معالجة.
- وجود تحديات مرتبطة بالوعي الأمني وإدارة الصلاحيات.

2.3 السياق الخارجي

يشمل السياق الخارجي:

- المتطلبات التنظيمية ذات العلاقة بالقطاع المصرفي.
- متطلبات SAMA.
- متطلبات حماية البيانات ذات العلاقة.
- التهديدات السيبرانية الخارجية.
- مخاطر التصيد الإلكتروني وبرمجيات الفدية وهجمات DDos.
- مخاطر الموردين وسلسلة التوريد.
- الاعتماد على أطراف خارجية وموردين وشركاء في تقديم بعض الخدمات.

تقرير تقييم مخاطر أمن المعلومات سري

وبناءً على ذلك، تم تصميم تقييم المخاطر بحيث يعكس طبيعة الخدمات المصرفية الرقمية والأصول والمخاطر الواردة ضمن معلومات المشروع.

2. 4 النطاق

يشمل تقييم المخاطر الأصول والمعلومات والأنظمة والخدمات المرتبطة بنظام إدارة أمن المعلومات في بنك الأفاق الرقمية، ومن ذلك:

- بيانات العملاء.
- بيانات الموظفين.
- المعلومات المالية والمحاسبية.
- معلومات الخزينة.
- التطبيقات المصرفية.
- قواعد البيانات.
- كود المصدر.
- إعدادات الشبكات والأمن.
- سجلات الأنظمة والأمن.
- تقارير الثغرات.
- الشهادات والمفاتيح التشفيرية.
- معلومات استمرارية الأعمال والتعافي من الكوارث.
- الأنظمة والبنية التحتية الداعمة للخدمات المصرفية الرقمية.

ولا يشمل التقييم أصولاً أو عمليات غير مرتبطة بنطاق ISMS أو لم يتم تحديدها ضمن معلومات المشروع.

2. 5 معايير قبول المخاطر

يتم تحديد قبول المخاطر بناءً على مستوى الخطر الناتج عن تقييم **Likelihood** و **Impact**، مع مراعاة أهمية الأصل وتأثير الخطر على سرية المعلومات وسلامتها وتوافر الخدمات.

كقاعدة تنفيذية للمشروع:

- تتم معالجة المخاطر ذات المستوى المرتفع.
- تتم معالجة المخاطر المرتبطة بحوادث فعلية أو أصول حرجية ما لم تعتمد الإدارة قبولها بشكل موثق.
- يمكن قبول المخاطر الأقل مستوى إذا كانت ضمن مستوى المخاطر المقبول الذي تعتمده الإدارة.
- يجب توثيق سبب قبول أي خطر وعدم ترك قرار القبول دون اعتماد.
- تتم إعادة تقييم المخاطر عند حدوث تغييرات مهمة في الأنظمة أو التهديدات أو البيئة التشغيلية.

3 ملخص نتائج تقييم المخاطر

أظهر تقييم المخاطر وجود مجموعة من المخاطر المرتبطة مباشرة بالأصول والحوادث والتهديدات والثغرات الواردة ضمن معلومات المشروع.

تركزت المخاطر ذات الأولوية على:

- فقدان أو كشف بيانات العملاء.
- الصلاحيات الزائدة على المعلومات الحساسة.
- التصيد الإلكتروني.
- أخطاء إعدادات الشبكة.
- انتهاء الشهادات الرقمية.
- الثغرات الأمنية غير المعالجة.
- ضعف المراقبة المركزية.
- مخاطر استمرارية الخدمات.
- هجمات DDoS.
- مخاطر سلسلة التوريد.

تم تصنيف المخاطر ذات التأثير المرتفع على المعلومات أو الخدمات على أنها تحتاج إلى **معالجة Treat**، بينما تتم مراجعة المخاطر الأخرى وفق معايير قبول المخاطر المعتمدة من الإدارة.

3.1 التقييم القائم على الأصول

رقم	الأصل	التهديد	نوع الخطر	مالك الخطر	المستوى	القرار
1	بيانات العملاء	فقدان أو كشف غير مصرح به لبيانات العملاء	السرية	CISO / مالك البيانات	مرتفع	معالجة
2	بيانات الموظفين	الوصول الزائد إلى معلومات الموارد البشرية	السرية	HR Manager / CISO	مرتفع	معالجة
3	المعلومات المالية والمحاسبية	التصيد الإلكتروني وما قد ينتج عنه من وصول غير مصرح به	السرية / السلامة	CFO / CISO	مرتفع	معالجة
4	معلومات الخزينة	وصول أو تعديل غير مصرح به	السلامة / السرية	Treasury Manager / CFO	مرتفع	معالجة
5	إعدادات الشبكات والأمن	خطأ بشري في الإعدادات يؤدي إلى توقف الخدمة	التوافر / السلامة	Network Security Manager	مرتفع	معالجة
6	سجلات الأنظمة والأمن	عدم كفاية المراقبة المركزية وتأخر اكتشاف الأحداث	التوافر / السلامة	SOC Manager / CISO	مرتفع	معالجة
7	تقارير الثغرات	بقاء الثغرات العالية والمتوسطة دون معالجة	السرية / السلامة / التوافر	Vulnerability Management Manager	مرتفع	معالجة
8	معلومات BCP وDR	عدم القدرة على استعادة الخدمات الحرجة بعد حدوث تعطل	التوافر	BCM Manager / CIO	مرتفع	معالجة
9	المفاتيح والشهادات التشفيرية	انتهاء شهادة TLS والتسبب في انقطاع الخدمة	التوافر / السرية	CISO / Security Operations	مرتفع	معالجة
10	معلومات التطبيقات المصرفية	استغلال الثغرات الموجودة في التطبيقات	السرية / السلامة / التوافر	Application Owner / CIO	مرتفع	معالجة

الجدول 3: ملخص نتائج تقييم المخاطر (قائم على الأصول)

3.2 التقييم القائم على السيناريوهات

رقم	الخطر / السيناريو	وصف الخطر	النوع	مالك الخطر	المستوى	القرار
1	خطأ في إعدادات Firewall	قد يؤدي تغيير إعدادات أمني بطريقة غير صحيحة إلى تعطيل الخدمات المصرفية الرقمية	التوافر / تشغيلي	Network Security Manager	مرتفع	معالجة
2	التصيد الإلكتروني في قسم المالية	قد تؤدي رسالة تصيد إلى الحصول على بيانات اعتماد أو الوصول غير المصرح به إلى المعلومات المالية	السرية / السلامة	CFO / CISO	مرتفع	معالجة
3	فقدان جهاز محمول غير مشفر	قد يؤدي فقدان جهاز غير مشفر إلى كشف بيانات العملاء المخزنة عليه	السرية	CISO / مالك الأصل	مرتفع	معالجة

تقرير تقييم مخاطر أمن المعلومات
سري

رقم	الخطر / السيناريو	وصف الخطر	النوع	مالك الخطر	المستوى	القرار
4	انتهاء شهادة TLS	قد يؤدي انتهاء الشهادة إلى انقطاع الخدمات التي تعتمد عليها	التوافر	Security Operations	مرتفع	معالجة
5	الصلاحيات الزائدة في مجلدات HR	استمرار صلاحيات غير ضرورية قد يؤدي إلى الوصول غير المصرح به إلى معلومات الموظفين	السرية	HR Manager / CISO	مرتفع	معالجة
6	الثغرات غير المعالجة	قد يتم استغلال الثغرات المعروفة قبل تنفيذ المعالجة	السرية / السلامة / التوافر	Vulnerability Management	مرتفع	معالجة
7	انخفاض الإبلاغ عن التصيد	قد يؤدي النقر على رسائل التصيد أو إدخال بيانات الاعتماد إلى زيادة احتمالية اختراق الحسابات	السرية / بشري	CISO / مسؤول التوعية	متوسط	معالجة
8	التعرض للتصيد في قسم التسويق	ارتفاع معدل النقر على رسائل التصيد يزيد من احتمالية التعرض للاختراق	السرية / بشري	Marketing Manager / CISO	متوسط	معالجة
9	هجوم DDoS على الخدمات المصرفية الرقمية	قد يؤدي هجوم حجب الخدمة إلى تعطيل الخدمات المصرفية الإلكترونية والمحمولة	التوافر	CISO / Network Security	مرتفع	معالجة
10	اختراق سلسلة التوريد	قد يؤدي اختراق مورد أو مكوّن تابع لطرف ثالث إلى التأثير على سرية أو سلامة أو توافر الخدمات	السرية / السلامة / التوافر	CIO / Third-Party Risk Owner	مرتفع	معالجة

الجدول 4: ملخص نتائج تقييم المخاطر (قائم على السيناريوهات)